



Q6	Compare against NIST CSF and identify control gaps	5 Marks
-----------	---	----------------

Objective: Assess the victim organisation against the five NIST CSF functions and list where controls were missing or weak.

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Write down the five NIST CSF functions as a checklist.	NIST CSF	Identify/Protect/Detect/Respond/Recover
2	ANALYSE	For each function, ask what the organisation did or failed to do.	Breach facts	Notes per function
3	TEST	Rate each function as Adequate, Partial or Missing.	Maturity scale	Rating per function
4	ANALYSE	For weak functions, state the specific control gap.	—	Gap statement
5	REPORT	Record the CSF assessment table and highlight the biggest gap.	Table template	CSF gap table

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH



Worked Example (with sample values & output)

NIST CSF gap assessment (Acme HealthCare)

CSF function	Rating	Gap identified
Identify	Partial	No up-to-date asset / data inventory
Protect	Missing	No MFA; weak email filtering
Detect	Missing	No monitoring of large data exports
Respond	Partial	IR plan existed but response was slow
Recover	Partial	Backups existed but were not tested

Biggest gap: the Detect function. The exfiltration went unnoticed until systems were locked, showing monitoring was the weakest area.

The Cost of Blindness: Breaking Down the Cyber Kill Chain's Deadliest Gap.

To analyze how the victim organization (GridSync Solutions) failed to stop Operation Iron Lattice, we can assess their security posture against the five core functions of the NIST Cybersecurity Framework (CSF 1.1/2.0): Identify, Protect, Detect, Respond, and Recover.

CSF function	Rating	Gap identified
Identify	1 / 5	Lack of Attack Surface Visibility • No digital footprint monitoring allowed open-source intelligence (OSINT) gathering on employee structures. • Lack of asset tracking failed to flag an unpatched edge VPN gateway exposed to the internet.
Protect	1/5	Absence of Proactive Hardening & Verification • Missing domain authentication protocols (DMARC, SPF, DKIM) allowed internal domain spoofing. • Deficient configuration management allowed unsigned macros to execute via Excel. • Failure to implement Application Whitelisting allowed standard binaries (mshta.exe) to execute untrusted scripts.
Detect	0/5	Zero Endpoint and Network Telemetry • Total lack of process-behavior monitoring; failed to alert when an Office application spawned a system script host. • Missing network anomalies baseline; encrypted outbound HTTPS command-and-control (C2) traffic bypassed perimeter checks uninspected.
Respond	1/5	No Internal Boundaries or Data Controls • Flat network architecture allowed uninhibited lateral movement from a standard user workstation directly to



		production Git code repositories. • Missing Data Loss Prevention (DLP) controls failed to block or trigger alerts on bulk encryption and unauthorized cloud exfiltration.
CSF function	Rating	Gap identified
Recover	3/5	Misalignment of Recovery Objectives • While data restoration and backup capabilities were likely functional, they were ineffective against data theft. • The gap lies in a missing data-breach playbook specific to intellectual property exposure, as traditional system recovery cannot reverse exfiltration.

Your Output / Screenshot (paste result here):

Biggest gap: The biggest gap in GridSync Solutions' security posture is its **total failure in the DETECT (0/5) function**, closely tied with critical enforcement failures in the **PROTECT (1/5)** function.

While a lack of protection (like letting a malicious macro run) allows an attack to start, a **complete absence of detection capabilities is fatal**. It turns a minor, preventable endpoint infection into a catastrophic, full-scale breach. Because the organization could not see or alert on abnormal behaviors, the attacker remained completely invisible for the entire duration of the lifecycle—from execution to exfiltration.

 Security Control Deficit Breakdown

To visualize where the organization's defensive coverage is missing, the chart below illustrates the distribution of the critical security control gaps discovered during the investigation of Operation Iron Lattice. The clear majority of the vulnerability lies heavily in their inability to observe and block activity inside the perimeter.



Operation Iron Lattice: Security Control Deficit Breakdown

